

Cybersecurity Engineering Internship Report

Phase 1: API Security Hardening, Rate Limiting & Access Controls

Name: Ashfaque Ali Channa

Focus Area: Defense-in-Depth Application Engineering & Traffic Policy Regulation

1. Executive Summary

Phase 1 focused on engineering defensive controls directly within the application tier to protect sensitive resources from unauthorized manipulation, brute-force disruption, and standard host enumeration vectors. By implementing robust HTTP header configurations, granular token authorization, and origin limitations, the core backend APIs were systematically insulated against common web exploits.

2. Environment Baseline & Target Deployment

The security baseline was conducted using an Express.js server architecture configured on a local development lab. Initial testing validated that unauthenticated or unthrottled interfaces could lead to complete exposure of backend functions.

3. Implementation of Rate Limiting & CORS Policies

To neutralize automated denial-of-service attempts and resource starvation, strict rate limiting was implemented via `express-rate-limit`. Concurrently, Cross-Origin Resource Sharing (CORS) rules were established to prevent unauthorized third-party domains from interacting with authenticated routes.

5. Host Perimeter Shielding & Intrusion Prevention

To bolster infrastructure security outside the application process boundary, server logs were paired with a local intrusion prevention engine (`fail2ban`). This system continuously audits systemic auth failures across edge entry points like SSH, isolating offending IP addresses automatically.

```
(kali@kali)~$ curl -i -H "x-api-key: SuperSecretMasterKey123" http://localhost:3000/api/secure-data
HTTP/1.1 200 OK
X-Powered-By: Express
RateLimit-Policy: 100;w=900
RateLimit-Limit: 100
RateLimit-Remaining: 95
RateLimit-Reset: 575
Access-Control-Allow-Origin: https://mytrustedfrontend.com
Vary: Origin
Content-Type: application/json; charset=utf-8
Content-Length: 99
ETag: W/"63-9w29vopI25lg0Xtd9tp3c41UGwQ"
Date: Thu, 04 Jun 2026 13:32:22 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"status":"Authenticated","confidentialData":"Top secret intelligence data accessed successfully."}
```

```
kali@kali ~
Session Actions Edit View Help

(kali@kali)~$ ssh wronguser@localhost
ssh: connect to host localhost port 22: Connection refused

(kali@kali)~$ sudo systemctl start ssh
[sudo] password for kali:

(kali@kali)~$ ssh wronguser@localhost
The authenticity of host 'localhost (::1)' can't be established.
ED25519 key fingerprint is: SHA256:+KjGkAeZbTFRbSqJqlvKg2xC+/mbr/UFJN9Qj0dnl
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
wronguser@localhost's password:
Permission denied, please try again.
wronguser@localhost's password:
Permission denied, please try again.
wronguser@localhost's password:
wronguser@localhost: Permission denied (publickey,password).

(kali@kali)~$
```

6. Phase 1 Conclusion

```
kali@kali: ~/api-security-lab
Session Actions Edit View Help
ls
4103BQ6
api-security-lab Desktop Downloads Mr.Holmes Music Number-Tracker PhoneinfoG phone_recon.fixed.sh Pictures quest.txt Templates vuln-node.js-express.js-app
phone_recon.sh Public seeker Videos worm-got

(kali@kali)~$ npm install helmet
added 1 package in 4s
1 package is looking for funding
  run 'npm fund' for details

(kali@kali)~$ nano server.js
(kali@kali)~$ node server.js
node:internal/modules/cjs/loader:1210
  throw err;
}

Error: Cannot find module 'express'
Require stack:
- /home/kali/server.js
    at Module._resolveFilename (node:internal/modules/cjs/loader:1207:15)
    at Module._load (node:internal/modules/cjs/loader:1038:27)
    at Module.require (node:internal/modules/cjs/loader:1209:19)
    at require (node:internal/modules/helpers:182:18)
    at Object.<anonymous> (/home/kali/server.js:1:17)
    at Module._compile (node:internal/modules/cjs/loader:1521:14)
    at Module._extensions._js (node:internal/modules/cjs/loader:1023:10)
    at Module.load (node:internal/modules/cjs/loader:1268:32)
    at Module._load (node:internal/modules/cjs/loader:1091:12)
    at Function.executeUserEntryPoint [as runMain] (node:internal/modules/run_main:164:12) {
  code: 'MODULE_NOT_FOUND',
  requireStack: [ '/home/kali/server.js' ]
}

Node.js v20.20.2

(kali@kali)~$ cd ~/api-security-lab
(kali@kali)~/api-security-lab$ ls
node_modules package.json package-lock.json server.js

(kali@kali)~/api-security-lab$ node server.js
[+] Injected env (0) from .env // tip: # override existing { override: true }
[+] Hardened API Server running successfully on http://localhost:3000
```

Phase 1 has established an exceptionally strong security baseline, integrating robust application controls with structural perimeter protection to defend against a wide range of common exploitation vectors.